- Passwords—on their own—provide poor security because of credential stuffing attacks, and their usability suffers from the need to register, remember, and recover them.
- One-time passwords sent via SMS or email provide better security than passwords alone, but their usability is reduced because users must often switch apps and manually enter the code. As shown in table 3.2, their security can be compromised using phishing or SIM swapping.
- One-time passwords from an authentication app are more secure because they're harder to intercept, but they still require switching apps and manually transferring the code. Phishing remains the most common attack vector in this context.
- Push notifications to an app are also hard to intercept and offer increased usability because, while you still switch apps, you don't need to transfer a code. Hackers bypass push notifications by using credential stuffing combined with MFA fatigue.
- Passkeys are the first level of the pyramid that is phishing-resistant. Because they resist phishing, passkeys are more secure than other authentication methods. Additionally, they are not vulnerable to MFA fatigue. The most common threats involve lost devices with weak security or malware infections that can expose the key store. Usability remains high because the underlying protocols handle generating and registering the key, storing it, and using it to respond to challenges.
- PKI may be more trustworthy than passkeys if the certificate issuer performs identity proofing. Similar to passkeys, the main threat is a lost device or a virus infection. However, the process of applying for and setting up certificates is generally not easy for non-technical people.

After studying figure 3.9, you might wonder, "Why don't we just use PKI for everything?" Besides usability, the biggest problem with using PKI for workaday authentication problems is its cost. Good certificates cost money because the issuer is doing work to verify that the certificate is valid and, potentially, providing identity proofing. User certificates were proposed in the 1990s, and some browsers still support them, but they have never been widely used.

The bottom line is that there's no reason not to use passkeys everywhere for everything. They are secure, affordable, and easy to use. The most likely